CONFIDENTIAL

# Vulnerability Assessment & Penetration Testing

Web Application Security Assessment Report

**Client: printing-thickeners.com**

Target: https://printing-thickeners.com

Report date: 03 October 2026

Version: 1.0 (Final)

This document contains confidential information intended solely for the named client. Do not distribute without authorisation.

# Document Control

| | |
|---|---|
| **Document title** | Vulnerability Assessment and Penetration Testing (VAPT) Report |
| **Target** | https://www.printing-thickeners.com (Angular front end with an /api/ back office) |
| **Third-party hosts observed** | translate.google.com (Google Translate widget) |
| **Assessment type** | Black-box web application security assessment (external, unauthenticated) |
| **Assessment date** | 03 October 2026 |
| **Report version** | 1.0 - Final |
| **Classification** | Confidential |

# Table of Contents

**Document Control** 2

**Table of Contents** 2

**1. Executive Summary** 3

**2. Scope and Methodology** 4

**3. Summary of Findings** 6

**4. Detailed Findings** 7

**5. Informational Observations** 13

**6. Remediation Roadmap** 14

**Appendix A - References** 15

**Appendix B - Disclaimer** 15

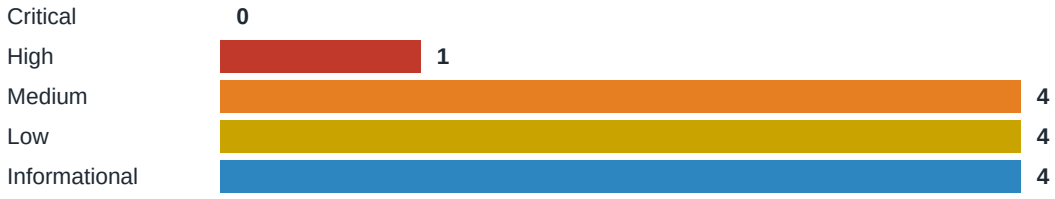
# 1. Executive Summary

A security assessment of the public website **www.printing-thickeners.com** was performed on 03 October 2026 to identify weaknesses that an external attacker could exploit. The test was black-box: no valid credentials or internal knowledge were used.

**Overall result.** The assessment produced **13 findings**: **1 High**, **4 Medium**, **4 Low** and **4 Informational**. The High finding is an outdated **bootstrap-select 1.12.4** library with a known XSS vulnerability. The most important configuration issues are an **open directory listing** of the upload folder, a **wildcard CORS policy** on the API, session cookies without Secure and SameSite attributes, and the absence of all common browser security headers.

| 0 | 1 | 4 | 4 | 4 |
|---|---|---|---|---|
| Critical | High | Medium | Low | Informational |

**Number of findings by severity (total: 13)**




## Key observations

- **Outdated component:** bootstrap-select 1.12.4 has a known XSS vulnerability (VAPT-01).
- **Information exposure:** the /api/uploads/ folder lists its contents to anyone (VAPT-02).
- **API and session handling:** wildcard CORS on the API gateway and session cookies without Secure/SameSite flags (VAPT-05, 06, 07).
- **No browser hardening headers:** CSP, X-Frame-Options, HSTS and X-Content-Type-Options were all absent in the sampled responses (VAPT-03, 04, 08, 09).
- **Exposed back office:** a login form is publicly reachable at /api/ (INFO-02) and should be restricted.
- **Positive points:** the site is served over HTTPS, the session cookie is HttpOnly, web server versions are not disclosed in headers, and no SQL injection or authentication bypass was identified by the tests performed.

## Recommendation in brief

Upgrade the vulnerable library, switch off directory listing, tighten CORS and cookie attributes, and add a small set of security headers at the nginx layer. Most items are low-effort configuration changes. A prioritised plan is given in Section 6.

# 2. Scope and Methodology

## 2.1 Scope

| Host | Description | Findings (High / Med / Low / Info) |
|---|---|---|
| https://www.printing-thickeners.com | **Target** - public website, API (/api/) and uploads folder | 1 / 4 / 4 / 4 |
| https://translate.google.com | Third-party Google Translate widget; observed only and out of scope | n/a |

Only the target host is assessed in this report. Requests were limited to GET and form submissions needed for crawling. No denial-of-service, social-engineering or physical tests were performed.

## 2.2 Methodology

The assessment followed an approach aligned with the **OWASP Web Security Testing Guide (WSTG)** and the **OWASP Top 10**:

| Phase | Activity |
|---|---|
| **1. Reconnaissance** | Identification of the technology stack (nginx, Apache, Angular front end, CodeIgniter-style back end) and publicly exposed paths. |
| **2. Crawling and mapping** | Spidering of the site and /api/ area to enumerate pages, scripts, forms and uploads. |
| **3. Passive analysis** | Inspection of requests and responses for outdated libraries, missing headers, cookie flags and information disclosure. |
| **4. Active testing** | Automated active checks such as directory browsing and User-Agent variation. |
| **5. Analysis and rating** | Triage, false-positive review, risk rating and remediation guidance. |

## 2.3 Tooling and limitations

Testing used an industry-standard automated dynamic application security scanner in passive and active modes, followed by manual review of the results. Please note:

- The assessment is a point-in-time view and does not replace in-depth manual penetration testing.
- Coverage was reduced by environment conditions: about 50% of requests failed or timed out and nearly all responses from the target were slow. Further findings cannot be ruled out.
- No authenticated testing was done. The back-office login at /api/ was not assessed beyond identification, and business logic, authorisation and API access control were not tested.
- Header findings are based on the responses sampled during the scan; individual routes behind the proxy may differ.
- Third-party hosts were observed but not attacked.

## 2.4 Risk rating model

| Rating | Definition | Suggested remediation window |
|---|---|---|
| **High** | Exploitable weakness with serious impact, or a known-vulnerable component in a sensitive area. | Within 7-14 days |
| **Medium** | Weakness that reduces defence-in-depth or can be exploited under specific conditions. | Within 30 days |
| **Low** | Minor weakness or hardening gap with limited impact on its own. | Within 60-90 days |
| **Informational** | No direct security impact; observation or context for the reviewer. | As part of routine maintenance |

# 3. Summary of Findings

| ID | Finding | Severity | Confidence | Occurrences |
|---|---|---|---|---|
| **VAPT-01** | Vulnerable JavaScript Library (bootstrap-select 1.12.4) | **High** | Medium | 1 |
| **VAPT-02** | Directory Browsing Enabled | **Medium** | Medium | 10 |
| **VAPT-03** | Content Security Policy (CSP) Header Not Set | **Medium** | High | Site-wide |
| **VAPT-04** | Missing Anti-clickjacking Header | **Medium** | Medium | Site-wide |
| **VAPT-05** | Cross-Domain Misconfiguration (Wildcard CORS on API) | **Medium** | Medium | Multiple |
| **VAPT-06** | Session Cookie Set Without Secure Flag | **Low** | Medium | 5 |
| **VAPT-07** | Session Cookie Without SameSite Attribute | **Low** | Medium | 5 |
| **VAPT-08** | Strict-Transport-Security (HSTS) Header Not Set | **Low** | High | Site-wide |
| **VAPT-09** | X-Content-Type-Options Header Missing | **Low** | Medium | Site-wide |
| **INFO-01** | Application Error Disclosure | **Info** | Medium | 18 |
| **INFO-02** | Authentication Request Identified | **Info** | Low | 1 |
| **INFO-03** | Session Management Response Identified | **Info** | Medium | 8 |
| **INFO-04** | Content-Type Header Missing | **Info** | Medium | 4 |

"Site-wide" means the condition was observed in every response sampled and applies to the whole host.

## Standards mapping

| Finding | CWE | OWASP Top 10 category |
|---|---|---|
| VAPT-01 Vulnerable JavaScript Library (bootstrap-select 1.12.4) | CWE-1395 | A06:2021 Vulnerable and Outdated Components |
| VAPT-02 Directory Browsing Enabled | CWE-548 | A05:2021 Security Misconfiguration |
| VAPT-03 Content Security Policy (CSP) Header Not Set | CWE-693 | A05:2021 Security Misconfiguration |
| VAPT-04 Missing Anti-clickjacking Header | CWE-1021 | A05:2021 Security Misconfiguration |
| VAPT-05 Cross-Domain Misconfiguration (Wildcard CORS on API) | CWE-264 | A01:2021 Broken Access Control |
| VAPT-06 Session Cookie Set Without Secure Flag | CWE-614 | A05:2021 Security Misconfiguration |
| VAPT-07 Session Cookie Without SameSite Attribute | CWE-1275 | A01:2021 Broken Access Control |
| VAPT-08 Strict-Transport-Security (HSTS) Header Not Set | CWE-319 | A05:2021 Security Misconfiguration |
| VAPT-09 X-Content-Type-Options Header Missing | CWE-693 | A05:2021 Security Misconfiguration |

# 4. Detailed Findings

Findings are ordered by severity. Each entry contains a description, supporting evidence, impact and recommended remediation.

| VAPT-01 | Vulnerable JavaScript Library (bootstrap-select 1.12.4) | | | | HIGH |
|---|---|---|---|---|---|
| **Severity** | High | **Confidence** | Medium | **Occurrences** | 1 |
| **CWE** | CWE-1395 | **OWASP** | A06:2021 Vulnerable and Outdated Components | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/assets/plugins/bootstrap-select/js/bootstrap-select.min.js`

### Description

The application serves **bootstrap-select v1.12.4**, a UI plugin with a publicly known cross-site scripting vulnerability (CVE-2019-20921) that is fixed in later releases. The library is delivered from the /api/ application area.

### Evidence

```
/*! * Bootstrap-select v1.12.4
```

### Impact

If option text or attributes processed by the plugin can be influenced by an attacker (for example through stored product or form data), script could be executed in the browser of an administrator or visitor. Exploitability depends on how the plugin is used, but running a library with a known XSS flaw on an area that includes a login form is a significant risk. Rated High by the scanner; confidence Medium because exploitability has not been manually confirmed.

### Recommendation

- Upgrade bootstrap-select to the latest stable release and re-test all dropdown components.
- Audit all places where user-supplied or database content is rendered into select options and ensure it is output-encoded.
- Maintain an inventory of front-end libraries and check it regularly with a software-composition tool (for example `npm audit` or Retire.js).

### References

https://owasp.org/Top10/2021/A06_2021-Vulnerable_and_Outdated_Components/
https://github.com/snapappointments/bootstrap-select/issues/2199

| VAPT-02 | Directory Browsing Enabled | | | | MEDIUM |
|---|---|---|---|---|---|
| **Severity** | Medium | **Confidence** | Medium | **Occurrences** | 10 |
| **CWE** | CWE-548 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/uploads/productbanners/`

### Description

The web server returns an automatic directory index for the upload folder, so anyone can list the files it contains. The listing was served by an Apache 2 server.

### Evidence

```
<title>Index of /api/uploads/productbanners</title>
```

### Impact

Directory listings reveal file names and structure, and may expose files that were never meant to be public (old uploads, backups, documents). They also make it easier to enumerate content for further attacks.

### Recommendation

- Disable directory indexing on all web servers and upload folders.
- Review the contents of /api/uploads/ and remove any file that should not be public.
- Consider serving uploads from a dedicated, non-executable location and validating file types on upload.

*Example configuration:*

```
# Apache (.htaccess or vhost)
Options -Indexes

# nginx
autoindex off;
```

### References

https://owasp.org/www-project-web-security-testing-guide/

| VAPT-03 | Content Security Policy (CSP) Header Not Set | | | | MEDIUM |
|---|---|---|---|---|---|
| **Severity** | Medium | **Confidence** | High | **Occurrences** | Site-wide |
| **CWE** | CWE-693 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/uploads/productbanners/`

### Description

The sampled responses (HTML, JavaScript and JSON) do not contain a **Content-Security-Policy** header. CSP restricts which sources of scripts, styles and frames a page may load and is the main browser-side defence against XSS.

### Evidence

```
Response headers checked: Server, Content-Type, Content-Length, Vary, Cache-Control - no
Content-Security-Policy header present.
```

### Impact

Combined with the vulnerable library in VAPT-01, the absence of CSP leaves no second layer of protection if a script-injection flaw is exploited.

### Recommendation

- Define a Content-Security-Policy and deploy it first in report-only mode.
- For the Angular front end, allow only your own origin plus the specific third-party hosts in use (for example the Google Translate widget).
- Apply the header at the nginx layer so it covers the API and static content.

*Example configuration:*

```
add_header Content-Security-Policy-Report-Only
  "default-src 'self'; script-src 'self' https://translate.google.com https://translate.googleapis.com;
   img-src 'self' data: https:; frame-ancestors 'self'; base-uri 'self'; object-src 'none'" always;
```

### References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

| VAPT-04 | Missing Anti-clickjacking Header | | | | MEDIUM |
|---|---|---|---|---|---|
| **Severity** | Medium | **Confidence** | Medium | **Occurrences** | Site-wide |
| **CWE** | CWE-1021 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/`

### Description

No **X-Frame-Options** header or CSP **frame-ancestors** directive was present in the sampled responses, so other websites can embed the pages inside a frame.

### Evidence

```
Header checked: x-frame-options - not present in the sampled responses.
```

### Impact

An attacker can overlay the site in a hidden frame and trick users into clicking hidden controls. This matters most for the login page at /api/ and any administrative functions.

### Recommendation

- Send `X-Frame-Options: SAMEORIGIN` (or DENY) on all responses.
- Also set CSP `frame-ancestors 'self'`.

*Example configuration:*

```
add_header X-Frame-Options "SAMEORIGIN" always;
```

### References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

| VAPT-05 | Cross-Domain Misconfiguration (Wildcard CORS on API) | | | | MEDIUM |
|---|---|---|---|---|---|
| **Severity** | Medium | **Confidence** | Medium | **Occurrences** | Multiple |
| **CWE** | CWE-264 | **OWASP** | A01:2021 Broken Access Control | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/api/gateway/`

### Description

The API gateway endpoint responds with **Access-Control-Allow-Origin: ***, allowing any website to read its responses from a visitor's browser.

### Evidence

```
Access-Control-Allow-Origin: * (observed on the /api/api/gateway/ response)
```

### Impact

A wildcard policy on an API lets arbitrary third-party sites query it from users' browsers. Browsers do not attach cookies to wildcard CORS requests, which limits the impact, but any data available without authentication (or protected only by IP or network position) can be read cross-origin.

### Recommendation

- Replace the wildcard with an explicit allow-list of the application's own origins.
- Do not combine permissive CORS with cookie-based authentication; keep endpoints that return user-specific data restricted.
- Review which API methods and routes actually need cross-origin access.

*Example configuration:*

```
Access-Control-Allow-Origin: https://www.printing-thickeners.com
Vary: Origin
```

### References

https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS
https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

| VAPT-06 | Session Cookie Set Without Secure Flag | | | | LOW |
|---|---|---|---|---|---|
| **Severity** | Low | **Confidence** | Medium | **Occurrences** | 5 |
| **CWE** | CWE-614 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/api/gateway/`

### Description

The session cookie **ci_session** is issued without the **Secure** attribute. It does carry **HttpOnly**, which is positive.

### Evidence

```
Set-Cookie: ci_session=...; expires=...; Max-Age=7200; path=/; HttpOnly
```

### Impact

Without the Secure flag the browser may transmit the session cookie over plain HTTP, where it could be captured on an untrusted network and used to hijack the session.

### Recommendation

- Set the Secure attribute on all session and authentication cookies.
- Enforce HTTPS-only access (see VAPT-08) so the cookie is never sent over HTTP.

*Example configuration:*

```
Set-Cookie: ci_session=<value>; Max-Age=7200; Path=/; Secure; HttpOnly; SameSite=Lax
```

### References

https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes

| VAPT-07 | Session Cookie Without SameSite Attribute | | | | LOW |
|---|---|---|---|---|---|
| **Severity** | Low | **Confidence** | Medium | **Occurrences** | 5 |
| **CWE** | CWE-1275 | **OWASP** | A01:2021 Broken Access Control | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/api/gateway/`

### Description

The **ci_session** cookie has no **SameSite** attribute, so the browser applies its default behaviour and the cookie may be sent with cross-site requests.

### Evidence

```
Set-Cookie: ci_session=...; path=/; HttpOnly (no SameSite attribute)
```

### Impact

SameSite is an effective defence against cross-site request forgery. Without it, state-changing requests on the login-protected area depend entirely on other CSRF controls.

### Recommendation

- Set `SameSite=Lax` (or Strict where possible) on session cookies.
- Verify that state-changing API calls also require a CSRF token or custom header.

### References

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Set-Cookie#samesitesamesite-value

| VAPT-08 | Strict-Transport-Security (HSTS) Header Not Set | | | | LOW |
|---|---|---|---|---|---|
| **Severity** | Low | **Confidence** | High | **Occurrences** | Site-wide |
| **CWE** | CWE-319 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/`

### Description

HTTPS responses do not include the **Strict-Transport-Security** header, so browsers are not instructed to use HTTPS exclusively.

### Evidence

```
No Strict-Transport-Security header in the sampled responses.
```

### Impact

Users who type the plain-HTTP address or follow old http:// links can be downgraded or intercepted before being redirected to HTTPS. With the cookie issue in VAPT-06 this increases the risk of session theft on hostile networks.

### Recommendation

- Enable HSTS with a max-age of at least one year.
- Ensure all HTTP requests are permanently redirected to HTTPS.

*Example configuration:*

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
```

### References

https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
https://datatracker.ietf.org/doc/html/rfc6797

| VAPT-09 | X-Content-Type-Options Header Missing | | | | LOW |
|---|---|---|---|---|---|
| **Severity** | Low | **Confidence** | Medium | **Occurrences** | Site-wide |
| **CWE** | CWE-693 | **OWASP** | A05:2021 Security Misconfiguration | | |

### Affected URL(s)

`https://www.printing-thickeners.com/api/assets/plugins/bootstrap-select/js/bootstrap-select.min.js`

### Description

Responses do not include **X-Content-Type-Options: nosniff**, so browsers may try to guess the content type instead of trusting the declared Content-Type. One resource (manifest.webmanifest) is additionally served without any Content-Type header.

### Evidence

```
Header checked: x-content-type-options - not present.
```

### Impact

MIME-sniffing can cause a browser to interpret uploaded or served files as a different type, which can enable content-injection attacks. This is relevant because the site has a public upload folder (VAPT-02).

### Recommendation

- Add `X-Content-Type-Options: nosniff` to all responses.
- Ensure every response carries a correct Content-Type header.

*Example configuration:*

```
add_header X-Content-Type-Options "nosniff" always;
```

### References

https://owasp.org/www-community/Security_Headers

# 5. Informational Observations

The items below are context or were assessed as duplicates / false positives, and are recorded for completeness.

| ID | Observation | Details | Suggested action |
|---|---|---|---|
| **INFO-01** | **Application Error Disclosure** (18 occurrences) | The scanner matched the text "Parent Directory" in directory listings and raised a possible error message. On review this is the directory index described in VAPT-02, not an application error or stack trace. Assessed as a **false positive / duplicate**. | Resolved by fixing VAPT-02. |
| **INFO-02** | **Authentication Request Identified** (1 occurrences) | A public login form exists at `/api/` (fields: Email, Password), apparently the back-office of the application. The scanner submitted dummy credentials; no authenticated testing was performed. | Restrict access to the back-office (IP allow-list or VPN), enforce MFA, rate-limit and lock out repeated login attempts. |
| **INFO-03** | **Session Management Response Identified** (8 occurrences) | The application issues a session cookie named `ci_session`, which suggests a CodeIgniter back end. Informational only. | No action beyond VAPT-06 and VAPT-07. |
| **INFO-04** | **Content-Type Header Missing** (4 occurrences) | Some responses, such as `/manifest.webmanifest`, are served without a Content-Type header. | Configure correct MIME types (for example application/manifest+json). |

## Environment notes

- The main site is served by **nginx** without version disclosure. The uploads folder was served by **Apache 2**, suggesting a second server or proxy layer behind nginx; both should be hardened consistently.
- The front end is a single-page application (Angular-style bundles such as `main-es2015.*.js`). The back end exposes an API under /api/api/gateway/ that rejects GET requests with HTTP 405 and returns JSON.
- The Google Translate widget is loaded from translate.google.com. Cookie and header observations on that host belong to Google and are outside the scope of this report.

# 6. Remediation Roadmap

| Priority | Action | Addresses | Effort | Target |
|---|---|---|---|---|
| **1** | Upgrade bootstrap-select and audit all front-end libraries | VAPT-01 | Low-Medium | 14 days |
| **2** | Disable directory listing; review and clean /api/uploads/ | VAPT-02 | Low | 7-14 days |
| **3** | Restrict the /api/ back-office login (IP allow-list or VPN, MFA, lockout) | INFO-02 | Low-Medium | 30 days |
| **4** | Restrict CORS to the application's own origins | VAPT-05 | Low | 30 days |
| **5** | Set Secure and SameSite on session cookies; enforce HTTPS and HSTS | VAPT-06, 07, 08 | Low | 30 days |
| **6** | Add X-Frame-Options, X-Content-Type-Options; roll out CSP in report-only mode | VAPT-03, 04, 09 | Low-Medium | 30-60 days |
| **7** | Fix missing Content-Type on manifest; confirm informational items | INFO-01..04 | Low | 90 days |

## Consolidated header baseline

The following nginx configuration closes VAPT-02 (nginx side), 04, 06 (together with application cookie settings), 08 and 09 in one change. Test in staging first and deploy CSP in report-only mode before enforcing.

```
# nginx (HTTPS server block)
autoindex off;
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;

# HTTP to HTTPS
server { listen 80; server_name www.printing-thickeners.com printing-thickeners.com;
         return 301 https://www.printing-thickeners.com$request_uri; }

# Apache (uploads folder)
Options -Indexes
```

## Retest

After remediation, a retest is recommended to verify closure of the High and Medium findings. Because coverage was affected by network failures, the retest should be run from a stable connection or an allow-listed source address, and should include authenticated testing of the back office and the API.

## 7. Conclusion

printing-thickeners.com has one High-rated issue (a library with a known XSS flaw) and several configuration weaknesses that are straightforward to fix. The open upload directory, permissive CORS policy and weak cookie attributes deserve prompt attention, and the back-office login should not be reachable by the whole internet. Addressing the roadmap would significantly reduce the site's exposure; an authenticated follow-up test is advised to cover the application logic that this external assessment could not reach.

# Appendix A - References

- OWASP Top 10 - https://owasp.org/Top10/
- OWASP Web Security Testing Guide - https://owasp.org/www-project-web-security-testing-guide/
- OWASP Secure Headers Project - https://owasp.org/www-project-secure-headers/
- MDN Web Docs: HTTP security - https://developer.mozilla.org/en-US/docs/Web/Security
- OWASP Session Management Cheat Sheet - https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- MITRE CWE - https://cwe.mitre.org/

# Appendix B - Disclaimer

This report reflects the security status of the in-scope systems at the time of testing and is based on the methods described in Section 2. It does not guarantee that the systems are free of vulnerabilities. The report is confidential and intended solely for the owner of the assessed systems; disclosure to third parties without written consent is prohibited.